GUÍA DE ESTUDIO

Arquitectura de Red Segura: DMZ, VLANs y Firewalls NGFW

UNIDAD	SEMANA	TIPO	NIVEL
U2	Sem 5	ESTUDIO	Avanzado

CUGDL — Universidad de Guadalajara
Arquitectura de Sistemas de Seguridad
Licenciatura en Ciberseguridad

Autor: Carlos Pulido Rosas
Marzo 2026

OBJETIVOS DE APRENDIZAJE

1. Explicar el propósito de la DMZ y cómo su posición en la arquitectura de red reduce la superficie de ataque expuesta a Internet.
2. Distinguir entre segmentación física y lógica de red, y diseñar un esquema básico de VLANs para separar tráfico por función y nivel de confianza.
3. Describir las capacidades de un Firewall de Nueva Generación (NGFW) y compararlo con un firewall tradicional en términos de visibilidad y control.

1. De la red plana a la red segmentada

La mayoría de los ataques exitosos no ocurren porque el perímetro falla - ocurren porque una vez dentro, el atacante puede moverse libremente. Una red plana donde todos los dispositivos comparten el mismo segmento es el escenario ideal para un atacante: comprometer una laptop de usuario es suficiente para alcanzar servidores críticos.

La segmentación de red resuelve este problema dividiendo la red en zonas con diferente nivel de confianza y controlando el tráfico entre ellas. DMZ, VLANs y firewalls son las tres herramientas principales para implementar esta segmentación.

	ANALOGÍA - Microservicios y namespaces
	Una red plana es como un monolito donde todos los servicios comparten el mismo proceso, un bug en un módulo puede tumbar todo.
	La segmentación con DMZ y VLANs es como Kubernetes con namespaces: cada zona tiene sus propios recursos y políticas de acceso.
	El firewall NGFW es el Ingress Controller: decide qué tráfico puede cruzar entre namespaces y qué se bloquea.

2. DMZ - Zona Desmilitarizada

La DMZ (Demilitarized Zone) es un segmento de red intermedio ubicado entre Internet (zona no confiable) y la red interna (zona confiable). Su función es alojar servicios accesibles desde Internet — servidores web, de correo, DNS públicos, sin exponerlos directamente a la red interna.

2.1 Arquitectura con DMZ

La implementación clásica usa dos firewalls: uno entre Internet y la DMZ, y otro entre la DMZ y la red interna. Esto crea tres zonas con niveles de confianza distintos:

- Zona externa (Internet) - nivel de confianza: ninguno. Todo el tráfico entrante se considera potencialmente hostil.
- DMZ - nivel de confianza: bajo. Solo los servicios públicos necesarios se ubican aquí. El compromiso de un servidor en la DMZ no debe dar acceso a la red interna.
- Zona interna - nivel de confianza: alto. Bases de datos, sistemas ERP, estaciones de trabajo. Nunca accesible directamente desde Internet.

Reglas de tráfico en una DMZ bien configurada

- Internet → DMZ: permitido solo en los puertos necesarios (443 para HTTPS, 25 para SMTP).
- DMZ → Internet: permitido para respuestas y actualizaciones controladas.
- Internet → Red interna: bloqueado completamente. Sin excepciones.
- DMZ → Red interna: bloqueado por defecto. Solo permitido en puertos específicos con autenticación (ej: servidor web en DMZ consulta BD interna por puerto 3306 solo con credenciales).
- Red interna → DMZ: permitido para administración de servidores.

2.2 Qué va en la DMZ y qué no

Va en la DMZ	No va en la DMZ
Servidor web (Apache, Nginx)	Base de datos de clientes
Servidor de correo (relay SMTP)	Servidor de Active Directory
Servidor DNS público	Sistema ERP o CRM
Balanceador de carga	Repositorio de código fuente
Proxy inverso (reverse proxy)	Estaciones de trabajo de empleados

3. VLANs - Segmentación Lógica de Red

Una VLAN (Virtual Local Area Network) permite dividir un switch físico en múltiples redes virtuales independientes. Dos dispositivos en VLANs distintas no pueden comunicarse directamente aunque estén en el mismo switch - necesitan pasar por un router o firewall que aplique políticas de acceso.

3.1 Segmentación física vs. lógica

3.2 Diseño típico de VLANs en una empresa

Un diseño bien estructurado separa el tráfico por función y nivel de confianza. Esquema típico para empresa mediana:

- VLAN 10 - Servidores internos: bases de datos, ERP, servicios críticos. Acceso solo desde VLAN de administración y aplicaciones autorizadas.
- VLAN 20 - Usuarios corporativos: estaciones de trabajo de empleados. Acceso a Internet y aplicaciones internas con autenticación.
- VLAN 30 - VoIP: tráfico de voz separado para garantizar calidad de servicio (QoS).
- VLAN 40 - Invitados y WiFi público: acceso solo a Internet. Completamente aislada de recursos internos.
- VLAN 50 - Administración: acceso exclusivo del equipo IT a switches, routers y firewalls. La VLAN más restringida.
- VLAN 99 - DMZ: tráfico de los servidores en la zona desmilitarizada.

	ANALOGÍA - Data Engineering y particionamiento
	Las VLANs son como particionar un Data Lake por dominio: ventas, finanzas, operaciones.
	Sin particionamiento, cualquier proceso puede leer cualquier dato. Con VLANs, cada segmento solo accede a su dominio.
	El firewall entre VLANs es el IAM que controla qué pipeline puede leer qué partición.

4. Firewalls NGFW - Next Generation Firewall

Un firewall tradicional filtra tráfico basándose en IP de origen/destino y puerto. Un NGFW agrega visibilidad profunda: identifica aplicaciones, usuarios e incluso contenido, independientemente del puerto que usen.

4.1 Firewall tradicional vs. NGFW

Capacidad	Firewall tradicional	NGFW
Filtrado por IP y puerto	Sí	Sí
Inspección de estado (stateful)	Sí	Sí
Identificación de aplicaciones	No	Sí | App-ID
Identificación de usuarios	No	Sí | User-ID
Inspección SSL/TLS	No	Sí
IDS/IPS integrado	No	Sí
Filtrado de URLs por categoría	No	Sí
Sandboxing de archivos	No	Sí (modelos avanzados)

4.2 Capacidades clave del NGFW

- Deep Packet Inspection (DPI): analiza el contenido del paquete, no solo el encabezado. Puede detectar malware en tráfico cifrado mediante inspección SSL/TLS.
- Application Awareness: identifica la aplicación real que genera el tráfico. Permite bloquear Netflix pero permitir YouTube, aunque ambos usen el puerto 443.
- User Identity: integra con Active Directory o LDAP para aplicar políticas basadas en usuario o grupo, no solo en IP.
- Threat Intelligence: se actualiza con feeds de amenazas para bloquear IPs, dominios y firmas de malware conocidos.
- Microsegmentación: aplica políticas granulares entre VLANs e incluso entre hosts individuales dentro de la misma VLAN.

Fabricantes principales de NGFW

- Palo Alto Networks - referente del mercado, introduce el concepto NGFW en 2007. Muy usado en enterprise y gobierno.
- Fortinet FortiGate - alta relación costo/rendimiento, muy común en PYME y mediana empresa en México y LATAM.
- Cisco Firepower (FTD) - integrado en ecosistemas Cisco. Común en universidades e instituciones.
- Check Point - fuerte en cumplimiento normativo y entornos financieros.

- pfSense / OPNsense - open source, sin costo de licencia. Usado en laboratorios y empresas con presupuesto limitado.

5. Cómo se integran DMZ, VLANs y NGFW

Estas tres herramientas no son alternativas - son capas complementarias. El NGFW es el punto de control que aplica políticas entre las zonas definidas por la DMZ y las VLANs.

En una arquitectura típica: el NGFW en el perímetro separa Internet de la DMZ y la red interna. Dentro de la red interna, los switches gestionados crean las VLANs por función. El NGFW aplica políticas entre VLANs y entre la red interna y la DMZ. El resultado es una arquitectura en capas donde cada zona tiene acceso mínimo al resto.

	ANALOGÍA - Microservicios con API Gateway
	La DMZ es el API Gateway público: expone solo los endpoints necesarios al mundo exterior.
	Las VLANs son los namespaces de Kubernetes: cada servicio vive en su propio espacio aislado.
	El NGFW es el Service Mesh: controla qué servicio puede llamar a qué otro y en qué condiciones.

6. IDS/IPS - Detección y Prevención de Intrusos

7. Defensa en Profundidad - El Principio que une todo

La defensa en profundidad (Defense in Depth) es el principio de diseño que establece que ningún control de seguridad es suficiente por sí solo. La seguridad efectiva requiere múltiples capas independientes - si una capa falla, las siguientes contienen el daño.

Este principio viene de la estrategia militar: en lugar de una muralla única y gruesa, se construyen múltiples líneas defensivas. Un atacante que rompe la primera línea se enfrenta inmediatamente con la segunda, luego la tercera, y así sucesivamente.

Capa	Control	Qué protege
Capa 1 - Perímetro	Firewall NGFW + DMZ	Separa Internet de la red interna
Capa 2 - Red	VLANs + segmentación	Limita el movimiento lateral entre zonas
Capa 3 - Detección	IDS/IPS	Identifica ataques que pasaron el perímetro

Capa 4 - Endpoint	Antivirus/EDR en dispositivos	Protege cada host individualmente
Capa 5 - Aplicación	WAF, autenticación MFA	Protege las aplicaciones y sus usuarios
Capa 6 - Datos	Cifrado, control de acceso	Protege los datos aunque el sistema sea comprometido
Capa 7 - Monitoreo	SIEM, logs centralizados	Detecta y responde a incidentes activos

	ANALOGÍA - Seguridad en capas como un pipeline de datos
	Capa 1 (firewall) es el schema validation de entrada: rechaza datos malformados antes de procesarlos.
	Capas 2-3 (VLANs + IDS/IPS) son los checks intermedios del pipeline: validan que los datos en tránsito son legítimos.
	Capas 4-6 (endpoint, app, datos) son las restricciones de acceso al Data Lake: aunque alguien entre al pipeline, no puede leer todo.
	Capa 7 (SIEM) es el observability stack: logs, métricas y alertas que detectan anomalías en tiempo real.

Defensa en profundidad no es redundancia

Un error común es pensar que defensa en profundidad significa duplicar el mismo control. No es así:

- Redundancia: dos firewalls iguales en paralelo - si uno falla, el otro toma el tráfico. Resuelve disponibilidad.
- Defensa en profundidad: un firewall + VLANs + IDS/IPS + cifrado. Cada capa resuelve un vector de ataque distinto.

La pregunta clave de diseño es: si esta capa falla completamente, ¿qué capa siguiente lo detecta o contiene?

CASO REAL: Target - Brecha por red plana (2013)

En 2013, atacantes comprometieron la red de Target a través de las credenciales de un proveedor de climatización que tenía acceso remoto a la red. Desde ahí se movieron lateralmente hasta los sistemas de punto de venta (POS) y robaron datos de 40 millones de tarjetas de crédito.

Conexión con esta guía: el proveedor externo nunca debió tener acceso a la misma red que los sistemas POS. Una VLAN dedicada para proveedores, aislada de los sistemas de pago, habría contenido el movimiento lateral. Un NGFW con políticas de segmentación habría

bloqueado la comunicación entre ambas VLANs. La red interna era plana - y eso fue suficiente para el atacante.

PREGUNTAS DE REFLEXIÓN

1. Un hospital quiere segmentar su red para separar dispositivos médicos IoT del sistema de expedientes y la WiFi de pacientes. Diseña un esquema de VLANs con al menos 4 zonas y justifica por qué cada dispositivo va en su VLAN.
2. Un NGFW puede descifrar tráfico SSL/TLS para inspeccionarlo. ¿Qué implicaciones tiene esto para la privacidad de los usuarios y el cumplimiento de GDPR? ¿Cuándo es aceptable y cuándo no?
3. El ataque a Target ocurrió en 2013. ¿Por qué crees que empresas grandes siguen operando con redes planas o segmentación insuficiente en 2026? ¿Es un problema técnico, económico u organizacional?

RECURSOS

- [Docs] Palo Alto Networks - What is a NGFW? - https://www.paloaltonetworks.com/cyberpedia/what-is-a-next-generation-firewall - gratuito
- [Docs] Cisco - VLAN Configuration Guide - https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst - gratuito
- [PDF] NIST SP 800-41 - Guidelines on Firewalls and Firewall Policy - https://csrc.nist.gov/publications/detail/sp/800-41/rev-1/final - gratuito
- [Video] NetworkChuck - VLANs explained - https://youtube.com/@NetworkChuck - aprox. 15 min
- [TryHackMe] Pre-Security: Network Fundamentals - https://tryhackme.com/path/outline/presecurity